04.10.2024

Romsis Bilgisayar Hizmetleri A.Ş.

SCA Analiz Raporu v1.0

Analiz Tarihi:

20.09.2024 – 03.10.2024

RSU
Bilişim ve Danışmanlık

GİZLİ

İçindekiler

YÖNETİCİ ÖZETİ 2
Test Kapsamı 4
Uyarı 4
Software Composition Analysis (SCA) 5
CVSS Seviyelendirmesi 5
SCA Analizi Metodolojisi 5
SCA Analizi Bulguları 6
1. Romsis Ajet Inflight 6
2. Romsis Ajet Mobile 7

YÖNETİCİ ÖZETİ

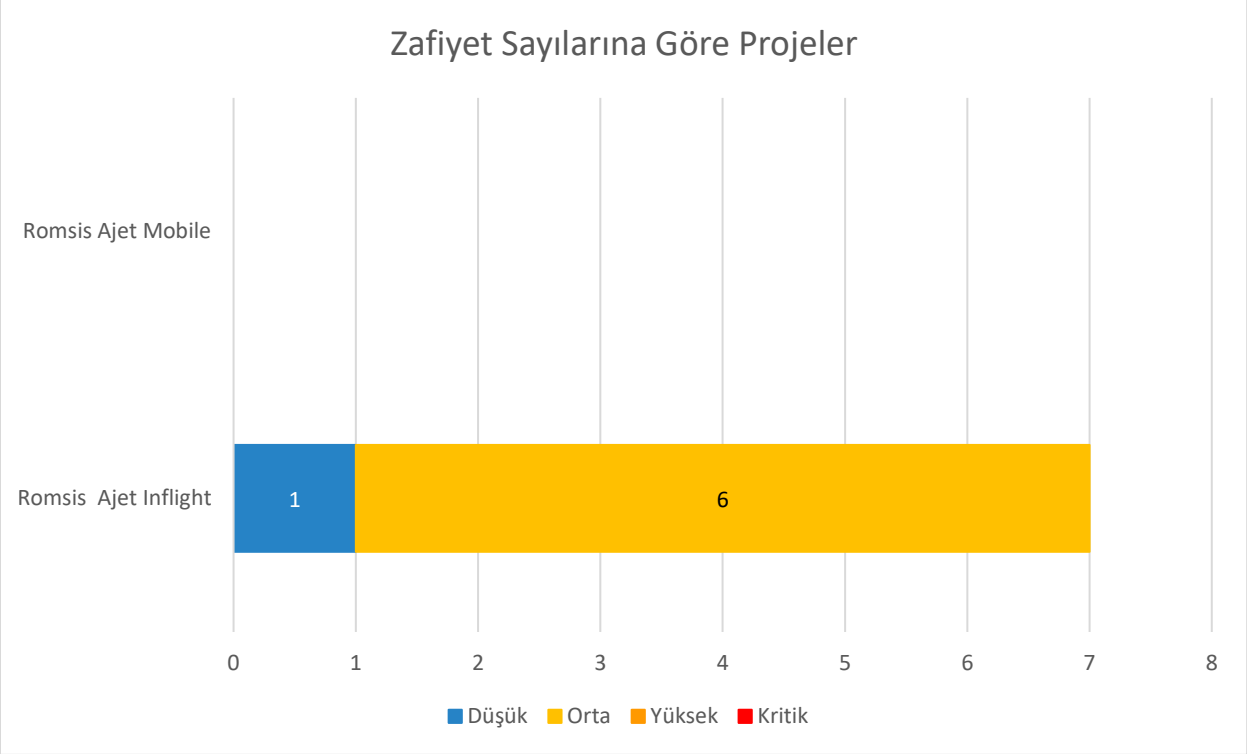
Romsis Bilgisayar Hizmetleri A.Ş. (Kurum) bünyesindeki Ajet Inflight ve Ajet Mobile projesindeki yazılımlarda kullanılan harici kütüphanelerindeki bilinen zafiyetleri için 20.09.2024 tarihinde NVD, Sonatype OSS ve GitHub Advisories veri setleri üzerinden analiz çalışmaları gerçekleştirilmiştir.

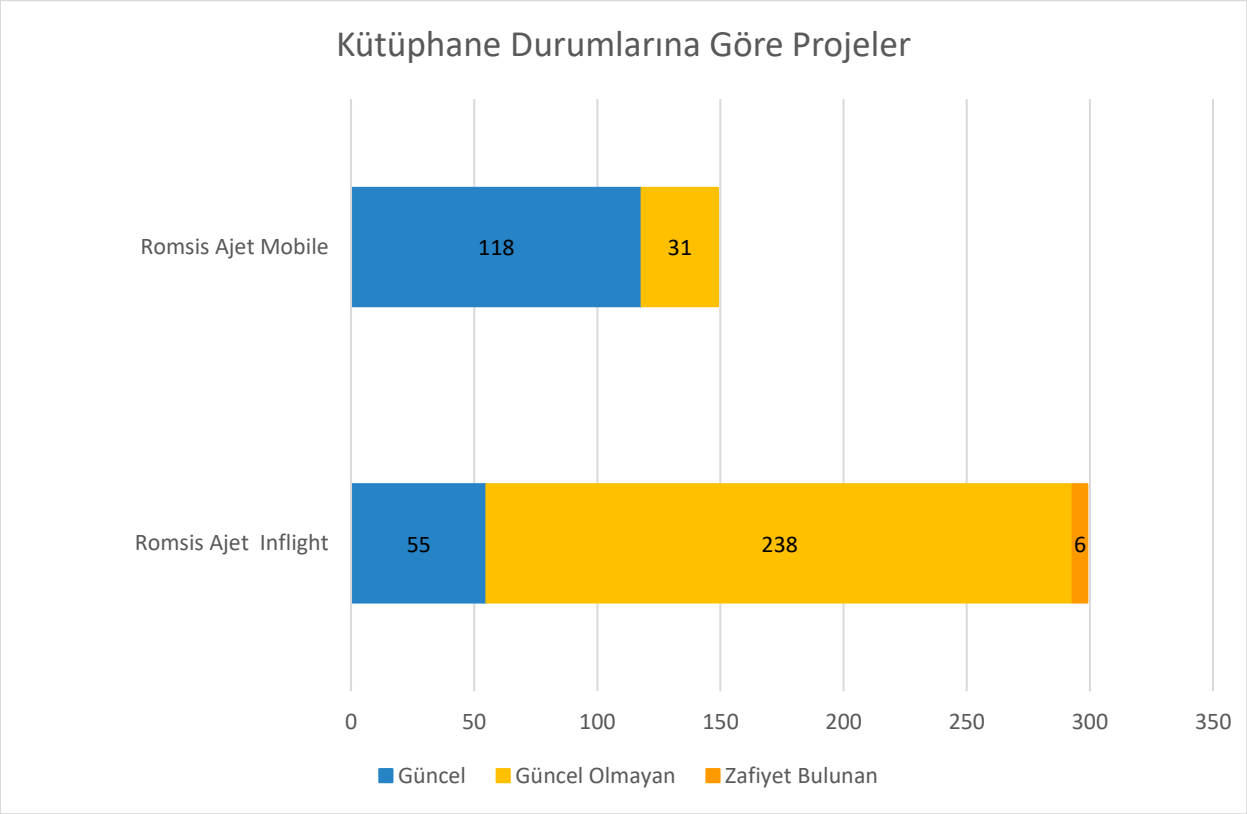
Analizler sonucunda, tespit edilen zafiyetler proje bazlı gruplanarak rapor içerisinde listelenmiştir.

Raporlanan 2 yazılım projesi özelinde 6 orta ve 1 düşük seviyeli zafiyet barındıran 4 kütüphanenin kullanıldığı tespit edilmiştir.

GİZLİ

Grafikler





GİZLİ

Test Kapsamı

Testi Gerçekleştiren Firma RSU Bilişim ve Danışmanlık Hizmetleri A.Ş.	**Test Kapsamı Veri Sahibi Firma** Romsis Yazılım ve Bilgi Teknolojileri
Testi Gerçekleştiren Personel Seçkin Güleviz	**Sorumlu Personel** Selim Tural
Test Başlangıç Tarihi 20.09.2024	**Raporlama Tarihi** 03.10.2024

Test Kapsamı
- Romsis Ajet Inflight
  ○ Zip SHA256: ad4fb97bf858ec64b759b13f19529d7eaf2e7d4a19a651030e7f4fb152fc9d7c
- Romsis Ajet Mobile
  ○ Zip SHA256: 37a70f6c3bee4acafb32714d8c84038c76d2c583cbcba0d291c9123bdd3e1995	

Uyarı

Rapor içeriği gizli olup iki tarafın yazılı mutabakatı olmadan üçüncü taraflara basılı olarak ya da elektronik ortamda transfer edilemez veya paylaşılamaz.

Rapor, tarama süresi içinde varlığı bilinen veya tarafımızdan tespit edilen güvenlik açıklıklarını içerecektir. Tarama işlemi bittikten sonra rapor teslim edilene kadar geçen süre içerisinde çıkabilecek yeni güvenlik açıklarına dair eksikliklerden dolayı RSU sorumlu tutulamaz.

Rapor içinde yer alan çözüm önerilerine konu hakkında fikir verme amaçlı yer verilmiştir. Çözüm önerilerinin uygulanması sebebi ile çıkabilecek problemlerden RSU sorumlu tutulamaz. Önerilerde sunulan değişikliklerden gerçekleştirilmeden önce konu hakkında uzman kişilerden destek alınması tavsiye edilir.

Software Composition Analysis (SCA)

Yazılım projeleri içerisinde kullanılan üçüncü taraf ve açık kaynak kodlu bileşenlere odaklanan bir yazılım bileşeni analizidir.

SCA, paket yöneticileri ile birlikte yazılım içerisinde kullanılan kütüphanelerin Software Bill of Material (SBOM) çıktısının oluşturulması ve bu çıktı üzerinden kütüphanelerin tespit edilen sürümleri üzerinden bilinen zafiyetlerinin analizi şeklinde ilerleyen bir süreçtir.

CVSS Seviyelendirmesi

Zafiyetler First tarafından standartlaştırılan CVSS 3.1 skorlaması üzerinden seviyelendirilmiştir. CVSS skorları yayınlarken seviyelendirme belirtmek zorunlu değildir fakat skorların seviyelendirmelerine karşılıkları hesaplanmak istenirse, spesifikasyonda önerilen tablo kullanılmaktadır.

CVSS Skoru	Seviye
0.0	None
0.1 - 3.9	Düşük
4.0 - 6.9	Orta
7.0 - 8.9	Yüksek
9.0 - 10.0	Kritik

SCA Analizi Metodolojisi

1. Hazırlık ve Planlama
    - Çalışma tarihi ve ortamının planlanması
    - Proje özelinde teknolojilerin belirlenmesi
    - Test ortamının oluşturulması
2. Analiz
    - Proje özelinde SBOM çıktılarının oluşturulması
    - SBOM çıktıları üzerinden bilinen zafiyetlerin analizi
3. Bulguların Değerlendirilmesi
    - False-Positive bulguların ayıklanması
4. Raporlama
    - Raporun hazırlanması

SCA Analizi Bulguları

1. Romsis Ajet Inflight

Kütüphane	Versiyon	Zafiyet (NVD)	Zafiyet (GHSA)	Seviye
System.Formats.Asn1	5.0.0	CVE-2024-38095	GHSA-447r-wph3-92pm	Orta
System.Formats.Asn1	6.0.0	CVE-2024-38095	GHSA-447r-wph3-92pm	Orta
System.Text.Json	8.0.0	CVE-2024-30105	GHSA-hh2w-p6rv-4g7w	Orta
Azure.Identity	1.10.3	CVE-2024-35255	GHSA-m5vv-6r4h-3vj9	Orta
Microsoft.Identity.Client	4.56.0	CVE-2024-35255	GHSA-m5vv-6r4h-3vj9	Orta
Azure.Identity	1.10.3	CVE-2024-29992	GHSA-wvxc-855f-jvrv	Orta
Microsoft.Identity.Client	4.56.0	CVE-2024-27086	GHSA-x674-v45j-fwxw	Düşük

2. Romsis Ajet Mobile

Yapılan incelemelerde güncel olmayan kütüphanelere rastlanmıştır fakat kullanılan kütüphanelerde bilinen zafiyetlere rastlanmamıştır.